NAME OF STUDENT: KELECHI KENNETH NWANKWO

REG NUMBER: 202529432VV

DATE: 25th AUGUST 2026

ISO/IEC 27001 Lead Implementer

ASSIGNMENT 2: Research-Based Implementation Strategy

CASE STUDY: The Capital One Breach (2019)

Rebuilding Trust in the Cloud
An ISO/IEC 27001:2022-Based Implementation Strategy for the Capital One Data Breach (2019)

Section 1: Executive Summary and Context

1.1 Overview of the Breach

In March 2019, Capital One Financial Corporation suffered one of the largest data breaches in the history of the U.S. financial services sector. A former Amazon Web Services (AWS) engineer, Paige Thompson, exploited a Server-Side Request Forgery (SSRF) vulnerability in a misconfigured Web Application Firewall (WAF) that Capital One had deployed in front of a credit-card application platform hosted on AWS. The SSRF flaw allowed Thompson to trick the WAF into relaying requests to the AWS Instance Metadata Service (IMDS), from which she retrieved temporary security credentials belonging to an IAM role. That role had been granted excessive permissions, including the ability to list and read the contents of more than 700 Amazon S3 storage buckets. Using these credentials, Thompson exfiltrated close to 30GB of data belonging to approximately 106 million individuals in the United States and Canada, including names, addresses, dates of birth, credit scores, bank account numbers, and roughly 140,000 Social Security numbers.

The intrusion began on or around 22 March 2019 but went undetected for almost four months. Capital One only learned of the breach on 19 July 2019, after an outside party who had seen Thompson boasting about the hack online notified the bank through its responsible-disclosure programme. The bank publicly disclosed the incident on 29 July 2019, the same day Thompson was arrested by the FBI. The regulatory and financial fallout was severe: the Office of the Comptroller of the Currency (OCC) imposed an $80 million civil money penalty for Capital One's "failure to establish effective risk assessment processes prior to migrating significant information technology operations to the public cloud environment," the Federal Reserve issued a parallel cease-and-desist order requiring board-level remediation, and the bank ultimately agreed to pay $190 million to settle consolidated class-action litigation.

1.2 Context of the Organization (Clause 4.1)

Clause 4.1 of ISO/IEC 27001 requires an organization to determine the internal and external issues that are relevant to its purpose and that affect its ability to achieve the intended outcomes of its Information Security Management System (ISMS). At the time of the breach, Capital One was in the midst of an aggressive, multi-year strategic pivot away from owning and operating physical data centres towards becoming a "cloud-first" bank built almost entirely on AWS. This migration, which began around 2015, was driven by genuine internal pressures: the need to compete with agile fintech entrants, the desire to reduce the cost and rigidity of legacy mainframe infrastructure, and a board-level mandate to accelerate digital transformation and modernize the customer-facing application experience for products such as online credit-card applications.

These internal pressures were not matched by a proportional investment in cloud-specific security governance. The organization's existing risk-management practices, developed for a traditional, perimeter-based on-premises environment, were not fully re-engineered for the shared-responsibility model that governs public cloud infrastructure, where the cloud provider secures the underlying infrastructure but the customer remains responsible for configuring identity, network, and application controls correctly. Externally, Capital One operated under a demanding regulatory context as a nationally chartered bank: it was subject to OCC safety-and-soundness supervision, the Gramm-Leach-Bliley Act's Safeguards Rule, PCI-DSS obligations tied to card processing, and an expanding patchwork of state data-breach notification laws. These external expectations assumed a level of technical risk assessment and control maturity that, as the OCC later found, had not kept pace with the speed of the cloud migration.

1.3 Interested Parties Harmed by the Breach (Clause 4.2)

Clause 4.2 requires the organization to identify interested parties relevant to the ISMS and their requirements. Several categories of interested parties were directly harmed or placed at risk by the breach:

- Consumers and small-business applicants approximately 106 million individuals whose personal, financial, and in some cases Social Security information was exposed, exposing them to identity theft and fraud risk for years afterward.

- Regulators and supervisory authorities the OCC, the Federal Reserve, and the Consumer Financial Protection Bureau, whose statutory mandate to ensure safe

and sound banking practices was undermined, required costly enforcement action and years of remediation oversight.

- Shareholders and investors Capital One's share price fell sharply following disclosure, and the organization incurred direct financial exposure exceeding $270 million in fines and settlements, in addition to remediation and legal costs.

- Employees and the security function staff bore the reputational and operational burden of emergency incident response, regulatory examinations, and a multi-year consent-order remediation programme.

- AWS, as the cloud service provider although AWS maintained that its own infrastructure was not compromised, the incident drew the shared-responsibility model, and by extension its brand, into public and legal scrutiny.

- In the broader financial sector and its customers, the breach became a reference case that shaped how regulators subsequently scrutinize cloud-risk governance across the industry, indirectly raising compliance costs for peer institutions.

Section 2: Root Cause Analysis through ISO/IEC 27001

Viewed purely as a technical event, the breach was caused by an SSRF vulnerability in a WAF and an over-permissioned IAM role. Viewed through the lens of ISO/IEC 27001, however, the technical failure was the visible symptom of deeper, systemic gaps in the management system that should have governed how Capital One planned, controlled, and monitored its cloud environment. At least three clauses from the core requirements (Clauses 4–10) were evidently absent or failing.

2.1 Clause 6.1 Actions to Address Risks and Opportunities

What the clause requires: Clause 6.1 obliges the organization to plan and perform an information security risk assessment before undertaking significant changes, and to select controls proportionate to the risks identified, recording the results in a Statement of Applicability.

The OCC's own enforcement finding stated plainly that Capital One failed to establish effective risk assessment processes prior to migrating significant information technology

operations to the public cloud. This is a direct, regulator-confirmed failure of Clause 6.1. Had a structured risk assessment been performed for the credit-application platform's move to AWS, it should have surfaced the risk that a public-facing WAF sitting in front of sensitive data stores, with access to the instance metadata service, represented a high-impact single point of failure. Because that risk was never formally assessed, no compensating control (such as network-layer blocking of the metadata endpoint, or a hardened IAM boundary) was ever selected or mandated. The absence of Clause 6.1 in practice meant the organization was reacting to a mature-sounding cloud strategy without the accompanying risk logic that ISO/IEC 27001 exists to enforce.

2.2 Clause 8.1 Operational Planning and Control

What the clause requires: Clause 8.1 requires the organization to plan, implement, and control the processes needed to meet information security requirements, including managing planned
changes and reviewing the consequences of unintended changes.

The WAF misconfiguration at the heart of the breach was, by definition, a change-control and configuration-management failure. Whether the specific error was a permissive WAF rule, a missing network ACL restricting access to the metadata service, or an overly broad IAM policy attached to the WAF's execution role, all three point to the absence of a disciplined process for defining, documenting, and verifying secure baseline configurations for internet-facing infrastructure. In a mature ISMS operating under Clause 8.1, configuration baselines would be defined, changes to firewall and IAM policy would go through review and approval, and drift from the approved baseline would be automatically detected. The fact that a single, longstanding misconfiguration went unnoticed for years until it was actively exploited demonstrates that operational control over this critical asset was not being planned or verified in the manner Clause 8.1 demands.

2.3 Clause 9.1 Monitoring, Measurement, Analysis and Evaluation

What the clause requires: Clause 9.1 requires the organization to determine what needs to be monitored and measured, and to evaluate the performance and effectiveness of the ISMS, including its ability to detect security events in a timely manner.

Perhaps the most damaging failure was temporal: the intrusion began around 22 March 2019 but was not discovered until 19 July 2019, roughly four months later, and only then because an external party stumbled across the attacker's own boasting rather than because Capital One's internal monitoring flagged the activity. The exfiltration of data from more than 700 S3 buckets, using credentials assumed through an unusual

metadata-service call pattern, should have generated anomalous log signals detectable by an effective security-monitoring capability. The absence of a working Clause 9.1 monitoring and evaluation programme meant that a detective control which should have functioned as a safety net for the Clause 6.1 and 8.1 failures was itself either not implemented, not tuned, or not reviewed for effectiveness, allowing a preventable data-loss event to continue undetected for months.

Together, these three clause failures reveal a pattern: risk was not properly assessed before the change was made (Clause 6.1), the resulting configuration was not properly controlled once it existed (Clause 8.1), and the organization had no reliable way of detecting when that uncontrolled configuration was actively being abused (Clause 9.1). This is precisely the type of systemic, management-system failure that ISO/IEC 27001 is designed to prevent; no single technical patch could have compensated for the absence of all three.

Section 3: The Risk Treatment Plan

The following analysis is written from the perspective of a Lead Implementer engaged by Capital One before the breach occurred, tasked with building the Statement of Applicability (SoA) for the credit-card application platform's move to AWS.

3.1 Risks That Were Ignored

A pre-breach risk assessment conducted in line with Clause 6.1 should have identified the following risks as high-priority items requiring treatment, none of which appear to have been formally assessed or mitigated in practice:

- The risk that a public-facing WAF, sitting between the internet and sensitive credit-application data, could be exploited to reach the cloud provider's internal metadata service (an SSRF-to-credential-theft pathway).

- The risk that a single compute role could be granted broad, standing access to hundreds of storage buckets far beyond what its function required, violating least-privilege principles.
- The risk that large-scale, anomalous outbound data transfer from cloud storage would go undetected in the absence of continuous, cloud-native security monitoring.

- The risk that highly sensitive personal data (Social Security numbers, bank account details) was stored in a form that offered no additional protection once perimeter and access controls were bypassed.

- The risk that governance and accountability for cloud security had not been clearly assigned between the bank's own risk function and its cloud service provider under the shared-responsibility model.

3.2 Selected Annex A Controls for the Statement of Applicability

At least five controls would have been mandated for inclusion in the SoA, each mapped to a specific risk and to the precise point in the attack chain it would have disrupted. A sixth is included because access-restriction and privilege management are functionally inseparable in this scenario and both were clearly absent.

Annex A Control	Control Name	Risk Addressed	Justification/How It Breaks the Attack Chain
A.5.23	Information security for use of cloud services	Uncontrolled cloud migration without defined security requirements or a shared-responsibilit y understanding with AWS.	Mandating a formal cloud-security policy and pre-migration risk assessment would have forced Capital One to explicitly define which party (bank or AWS) owned each control, including WAF configuration and metadata-service exposure, closing the exact governance gap the OCC later cited.
A.8.9	Configuration management	The WAF and its network boundary were configured in a way that permitted SSRF requests to reach	A documented, approved secure-configuratio n baseline for the WAF including blocking outbound

		the internal metadata endpoint.	requests to 169.254.169.254 and enforcing IMDSv2 (which requires a session token and defeats simple SSRF-based credential theft) would have neutralized the very mechanism the attacker used to obtain credentials.
A.8.3 / A.8.2	Information access restriction & Privileged access rights	The IAM role attached to the WAF held excessive, standing permissions to list and read content across more than 700 S3 buckets.	Enforcing least-privilege access scoping the WAF's role to only the narrow function it needed, with no broad S3 list/read rights would mean that even a successful SSRF exploit yielded credentials with negligible value, breaking the second link in the attack chain.
A.8.8	Management of technical vulnerabilities	A known class of vulnerability (SSRF) in web-facing application infrastructure was not identified or remediated before exploitation.	A structured vulnerability-management programme, including regular scanning and configuration review of the ModSecurity WAF and the applications behind it, increases the likelihood that the SSRF weakness would have been

			identified and patched during routine assessment rather than discovered by an attacker.
A.8.16	Monitoring activities	Months of large-scale, anomalous data access and exfiltration from S3 buckets went undetected.	Continuous monitoring of API calls, unusual credential-usage patterns, and abnormal data-transfer volumes (equivalent to modern cloud-native detection tooling) would have generated an alert within hours of the March 2019 intrusion rather than allowing it to continue until July, sharply limiting the volume of data exposed.
A.8.24	Use of cryptography	Highly sensitive fields, including Social Security numbers, were exposed in a form usable by the attacker once the buckets were accessed.	Mandating strong encryption and/or tokenization of the most sensitive data elements at rest, with keys managed outside of the compromised role's reach, would have meant that even a successful exfiltration produced data of substantially reduced value and harm to affected

			individuals.

Taken together, these controls form layered, defence-in-depth treatment of the risk: A.5.23 and A.8.9 would have prevented the SSRF pathway from ever reaching the metadata service; A.8.2/A.8.3 would have made the stolen credentials worthless even if that pathway had been reached; A.8.8 increases the chance the underlying vulnerability is found and fixed proactively; A.8.16 provides a detective safety net that limits the duration and scale of any breach that nonetheless occurs; and A.8.24 limits the harm caused by any data that is still exfiltrated despite the preceding controls. No single control would have been sufficient on its own but as a set, mandating these six in the SoA would very likely have prevented the incident entirely, or reduced it to a minor, quickly contained event rather than a 106-million-record breach.

Section 4: Implementation Roadmap

The following six-month roadmap is structured around the Plan-Do-Check-Act (PDCA) cycle that underpins ISO/IEC 27001's approach to continual improvement, and is designed both to close the specific technical gaps identified in Section 2 and 3 and to rebuild trust with regulators, customers, and shareholders.

PDCA Phase	Key Actions
PLAN (Months 1–2)	● Commission an independent forensic and root-cause review; formally brief the OCC, Federal Reserve, and CFPB with findings and a remediation timeline. ● Appoint or elevate a Chief Information Security Officer with a direct reporting line to the Board Risk Committee. ● Re-scope the ISMS to explicitly cover all cloud workloads and re-run a full Clause 6.1 risk assessment across the AWS environment, prioritising internet-facing services. ● Draft a revised cloud-security policy (A.5.23) defining the shared-responsibility split with AWS and mandatory security baselines for any new cloud deployment.

DO (Months 2–4)	● Enforce IMDSv2 and network-layer blocking of the metadata service across all EC2-based workloads; remediate the WAF configuration baseline (A.8.9). ● Conduct an IAM-wide least-privilege review, revoking excessive standing permissions and replacing broad roles with narrowly scoped, time-limited access (A.8.2/A.8.3). ● Deploy continuous cloud-security monitoring and anomaly detection across all storage and identity services, with defined alert thresholds and an on-call response process (A.8.16). ● Roll out encryption/tokenization for all high-sensitivity data fields, including Social Security numbers, with key management separated from application roles (A.8.24).
CHECK (Months 4–5)	● Commission an internal ISMS audit (Clause 9.2) against the revised controls, plus independent third-party penetration testing focused on SSRF and cloud-metadata attack paths. ● Run cross-functional tabletop exercises simulating a repeat cloud-breach scenario to test detection and response times end to end. ● Conduct a formal management review (Clause 9.3) presenting audit results, residual risk, and regulator feedback to executive leadership and the Board.
ACT (Months 5–6)	● Log and track corrective actions (Clause 10.1) arising from the audit and penetration test, with named owners and closure deadlines. ● Formalise continual improvement (Clause 10.2) by embedding periodic cloud-configuration reviews and threat-intelligence updates into business-as-usual operations. ● Publish a transparency report to customers and regulators summarising remediation completed, and establish a recurring quarterly reporting cadence with

	the OCC and Federal Reserve to rebuild supervisory trust. ● Pursue external validation (e.g., ISO/IEC 27001 certification audit) as an independent signal of restored control maturity to customers, investors, and regulators.

This roadmap mirrors, in substance, the remediation path Capital One itself was ultimately required to follow: the OCC's consent order remained in force until September 2022 and the Federal Reserve's parallel enforcement action was not terminated until July 2023, illustrating that even a well-run six-month sprint is realistically only the foundation of a multi-year programme of sustained oversight, independent audit, and demonstrated control effectiveness before full regulatory and stakeholder trust is restored.

Section 5: Conclusion and Reflection

The Capital One breach illustrates both the value and the limits of a management-system standard such as ISO/IEC 27001. Had a properly implemented ISMS been in place with genuine risk assessment ahead of cloud migration (Clause 6.1), disciplined configuration control over internet-facing infrastructure (Clause 8.1), and effective, continuously reviewed monitoring capable of detecting anomalous data access (Clause 9.1) it is highly likely that either the SSRF exploit would never have succeeded, or the resulting exfiltration would have been detected and contained within hours rather than months. In that sense, the standard's structured, plan-do-check-act discipline directly addresses the systemic gaps that produced this breach.

However, ISO/IEC 27001 certification cannot and does not guarantee that a breach will never happen. The standard is explicitly risk-based rather than risk-eliminating: Clause 6.1 asks an organization to identify, evaluate, and treat risk to an acceptable residual level, not to reduce risk to zero, which is neither technically achievable nor economically rational. Certification also measures the existence and operation of a management system at a point in time; it cannot, by itself, prevent a single engineer from making a configuration error, a determined and technically sophisticated insider or former insider from exploiting inside knowledge of a cloud provider's architecture, or a genuinely novel vulnerability from emerging between audit cycles. A compliant ISMS is a means of making breaches significantly less likely and, when they do occur, far faster to detect and less damaging in scale but it manages risk rather than abolishing it.

There is also a subtler limitation worth reflecting on: a certified ISMS is only as effective as the rigor with which it is operated day to day. An organization can hold a valid

ISO/IEC 27001 certificate while still allowing controls to decay into "paper compliance" if leadership commitment (Clause 5.1), competence (Clause 7.2), and internal audit (Clause 9.2) are treated as periodic, box-ticking exercises rather than living disciplines. Capital One's own experience a bank with mature governance structures and significant security investment, brought down by a control gap that a rigorous, continuously enforced risk-assessment and monitoring regime should have caught is a reminder that the framework's value lies entirely in how faithfully and continuously it is implemented, not merely in whether it is adopted.

References

Acunetix. (2019). Misconfiguration causes a leak of one hundred million financial records.
Acunetix Blog.

AuditBadger. (2025). ISO 27001 Annex A controls: The complete 2022 guide.
Banking Dive. (2023, July 12). Fed ends Capital One breach-related enforcement action.

Banking Dive. (2022, September 19). OCC frees Capital One from consent order tied to 2019
breach.

Cybersecurity Dive. (2022, September 20). Capital One freed from consent order tied to 2019
breach.

Krebs, B. (2019, August). What we can learn from the Capital One hack. KrebsOnSecurity.

MIT Center for Advanced Manufacturing Systems. A case study of the Capital One data breach.

Office of the Comptroller of the Currency. (2020, August 6). OCC assesses $80 million civil
money penalty against Capital One [Press release].

Secureframe. (2024). ISO 27001 controls explained: A guide to Annex A.

Security.org. (2026). Capital One data breach: What happened and what to do.

International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information security,
cybersecurity and privacy protection Information security management system requirement

International Organization for Standardization. (2022). ISO/IEC 27002:2022 Information
cybersecurity and privacy protection Information security controls.